

Fundamentals of Information Systems Security

Chapter 8 Quiz Answer Key

Instructor: Guuleed Maxamuud Aw Abdi

Section A: Multiple Choice (40 points)

1. **A** — A physical location where security administration occurs
2. **A** — Security Information and Event Management
3. **B** — Giving users the minimum access necessary to perform their job
4. **A** — Breaking tasks into subtasks performed by different users
5. **D** — Passwords
6. **A** — To ensure personnel are aware of and comply with policies
7. **A** — RFC 1087
8. **A** — A documented minimum level of security configuration
9. **A** — Policy is strategic; procedure is operational
10. **A** — To oversee all proposed changes to systems and networks

Section B: True/False (20 points)

1. **True** — Job rotation helps prevent fraud
2. **False** — Mandatory vacations are effective for fraud detection
3. **True** — Security Administration handles access control
4. **False** — Event logs are essential for incident investigation
5. **False** — Outsourcing has disadvantages (lack of internal knowledge, ongoing costs)
6. **True** — SLA is a contract with a third-party vendor
7. **True** — Change control should be multidisciplinary
8. **False** — Waterfall is sequential; agile is iterative
9. **True** — Certification reviews security requirements
10. **True** — Accreditation is formal acceptance of risk

Section C: Short Answer (40 points)

1. Policy Hierarchy (10 points)

- **Policy:** Executive-level statements setting organizational direction — high-level
- **Standards:** Detailed definitions for consistent security controls — mandatory
- **Procedures:** Step-by-step implementation instructions — operational
- **Guidelines:** Suggested actions and best practices — recommended

2. Personnel Security Principles (10 points)

- **Least Privilege:** Minimum access necessary to perform duties
- **Need-to-Know:** Access only to information required for job, regardless of clearance
- **Separation of Duties:** Breaking tasks into subtasks performed by different users
- **Job Rotation:** Rotating employees among various duties to prevent collusion
- **Mandatory Vacations:** Required time off to detect potential fraud

3. Elements of a Comprehensive BCP (10 points)

- (a) **Policy Statement:** Defines policy, standards, procedures, guidelines
- (b) **Project Team:** Members with defined roles and responsibilities
- (c) **Emergency Response:** Procedures for life safety and infrastructure protection
- (d) **Damage Assessment:** Situation and damage assessment protocols
- (e) **Resource Recovery:** Plans for resource salvage and recovery

4. Certification vs. Accreditation (10 points)

- **Certification:** Technical evaluation of a system to ensure it meets security requirements; performed by certifier
- **Accreditation:** Formal management acceptance of risk; authorizing official approves system for operation
- Certification validates requirements; Accreditation accepts risk